

Catch Me If You Can: Hooking your way into encrypted IoT traffic

Poking and fuzzing "backends"
(for science...)

Little Disclaimer

This talk is not a political discussion.

It's also not an excuse for someone to be racist,
xenophobic or other shitty things.

M is for Mansoor

- Tester of pens (SE and appsec mostly)
- Professional bridge burner
- Former press photographer
- Love to phish
- Don't love fish



What, when, why?

The Attack Surface

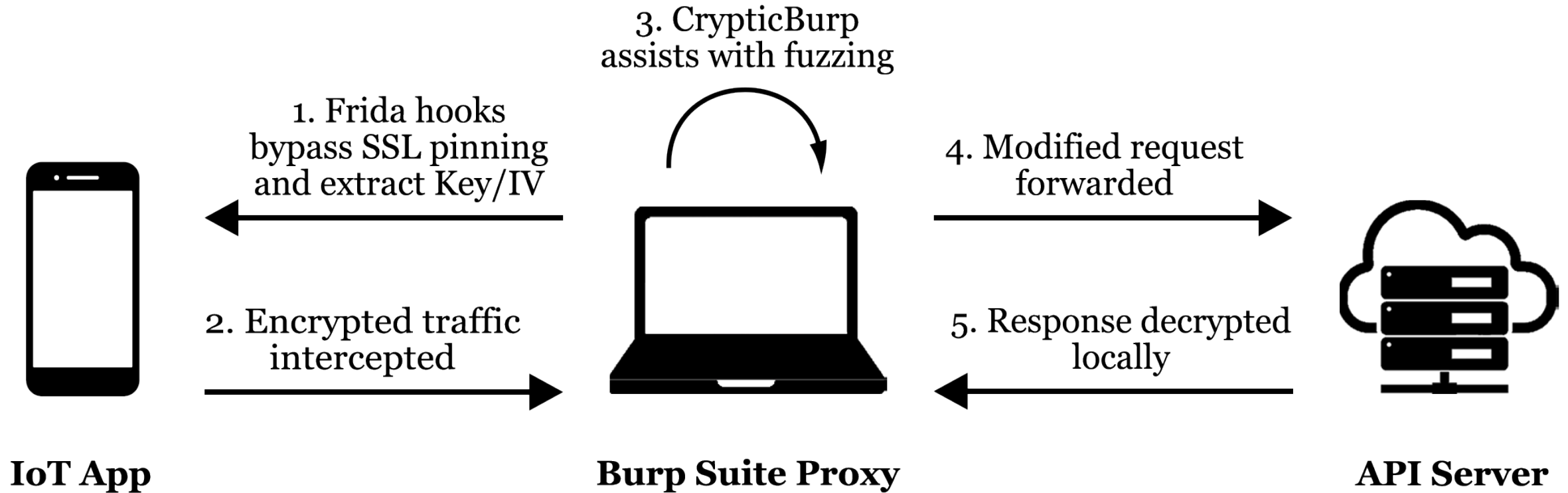
- Many types of consumer devices on large, online retail platforms
- Primary focus: intimate IoT devices ('adult toys')
- Prior work focused on Bluetooth
 - The caveat: Bluetooth attacks need physical proximity
- Network API layer is remote, over the internet
- Research question:
 - Does application-layer encryption in these apps provide meaningful security, or does it just look like it does?

The Encryption Layers

- Both apps encrypt every HTTP request and response at the application layer, using AES, on top of TLS
- ~23% of top Android apps do this
- 'First-look' protections:
 - No traffic inspection
 - No endpoint analysis
 - No parameter fuzzing
- Testing stops here for most

Two Apps, Two Paths

	Application A	Application B
Protection	Pinning and AES	AES only
Approach	Dynamic (Frida)	Static (JADX)
Key Source	Extracted from memory	Found in source code



Y tho

Used by

4 out of 5

Or -80% of all Chinese intimate IoT devices on Amazon

Story time!

Quick Primer: AES, CBC, ECB

- AES: symmetric cipher, 16-byte blocks
 - Needs a key, an IV, and a mode
- CBC (Cipher Block Chaining)
 - Each block XORed with the previous ciphertext block
 - IV seeds the first block
 - Only works if the IV is unpredictable
- ECB (Electronic Codebook)
 - Each block encrypted independently
 - Same plaintext block, same ciphertext block, every time
 - Leaks structure

middle aged man selfie - Google

google.com/search?q=middle+aged+man+selfie&oq=middle+aged+man+selfie&gs_lcrp=EgZjaHJvbWUyBggAEE...

Google

middle aged man selfie

AI Mode

All

Images

Videos

Shopping

Short videos

News

More

Tools

Images



19,000+ Middle Aged...
iStock



The March Divide | Hey, I...
Instagram



Selfie headshot since ...
Instagram



I am 33yrs old today, ...
Facebook



18,600+ Old Man Selfie Stock ...
iStock



Twitter "old folks" ho...
Twitter



Musings of a Middle-aged ...
www.fosters.com



14+ Thousand Mature Man Selfi...
Shutterstock



Page 6 | Man selfie ...
Freepik



11,168 Middle Aged ...
Getty Images

13



🔒 Biometrics never leave this device

Hold your phone at eye level

Processing hold still



camera 1, facing front





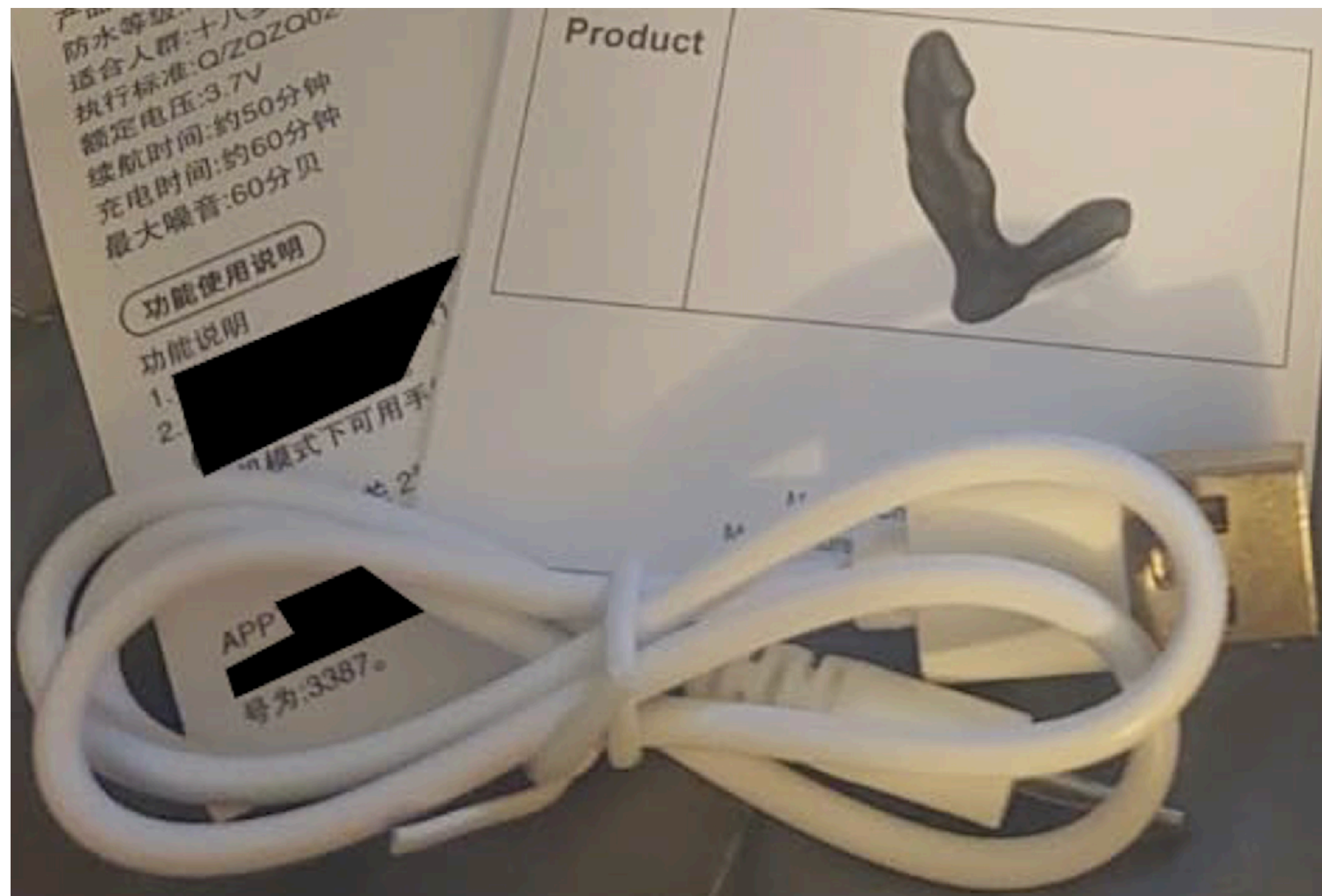
Your age is verified

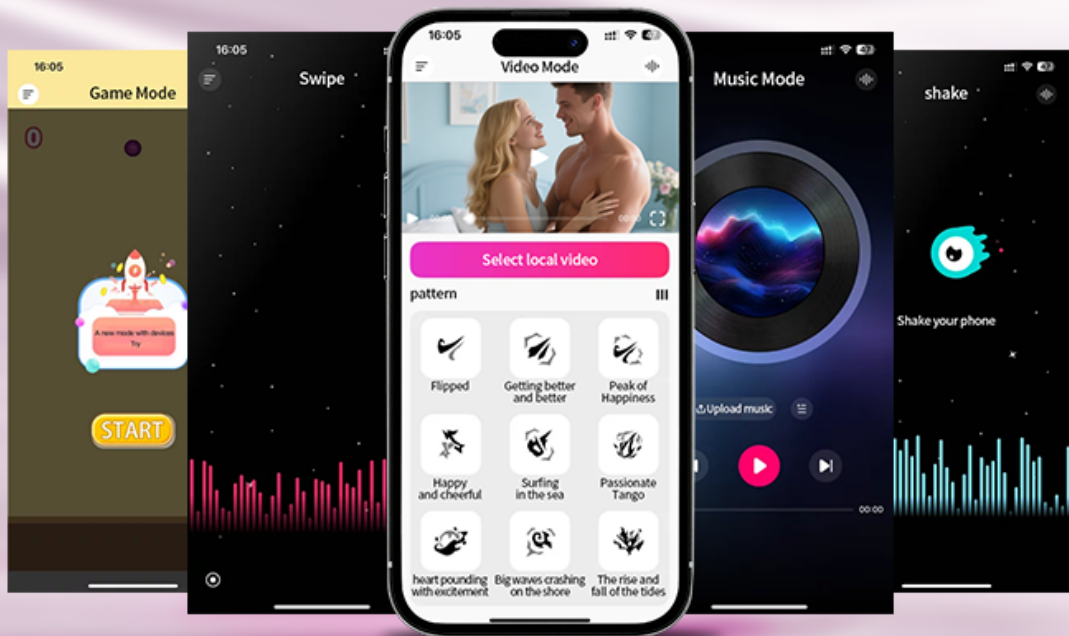


b[REDACTED]@gmail.com



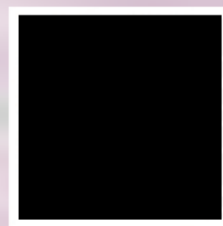






HOW TO USE APP CONTROL

1. Scan code in APP Store or Google play to download and install [REDACTED]
2. Register account and log in.
3. Scan the product code or enter the product code 2984 to bind the toy.
4. Add friends for remote interactions.



APP
(IOS / Android)

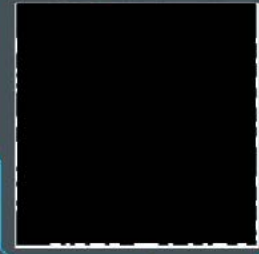


Product
" 2984 "

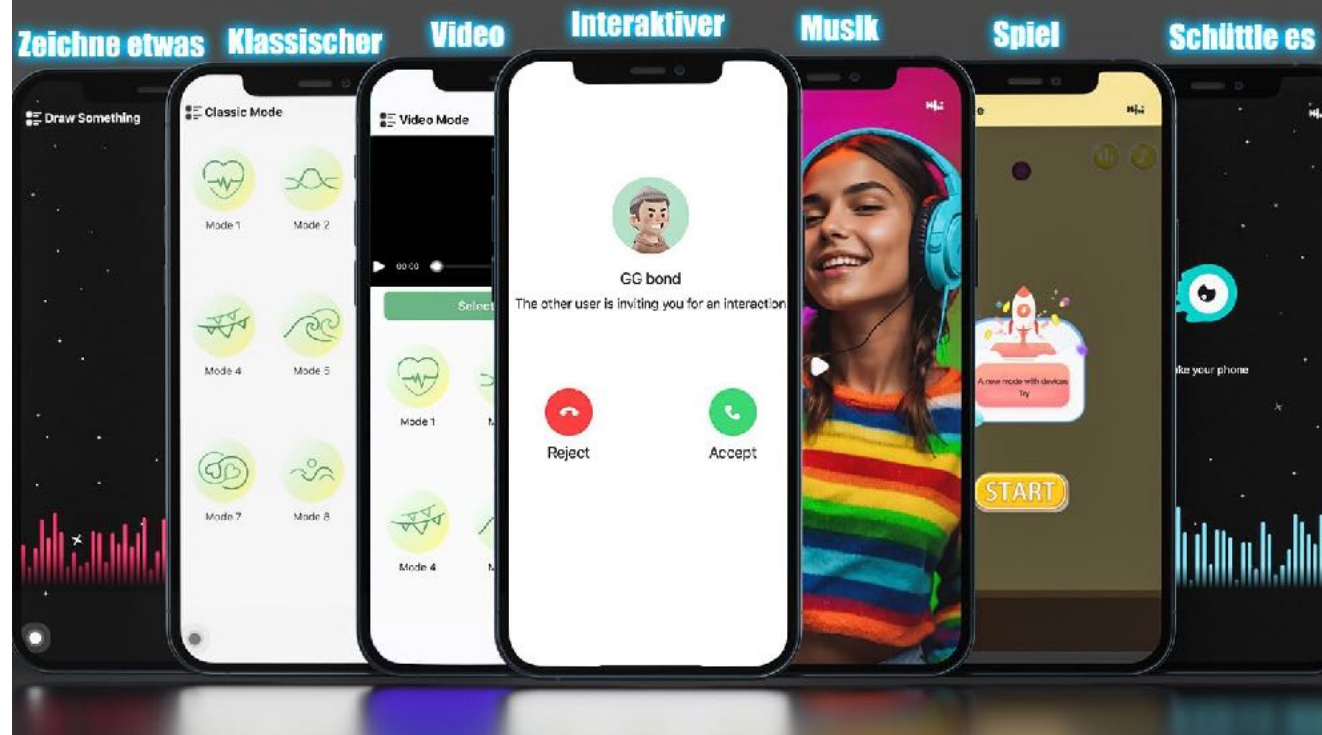
DIFFERENT PLAYING STYLES

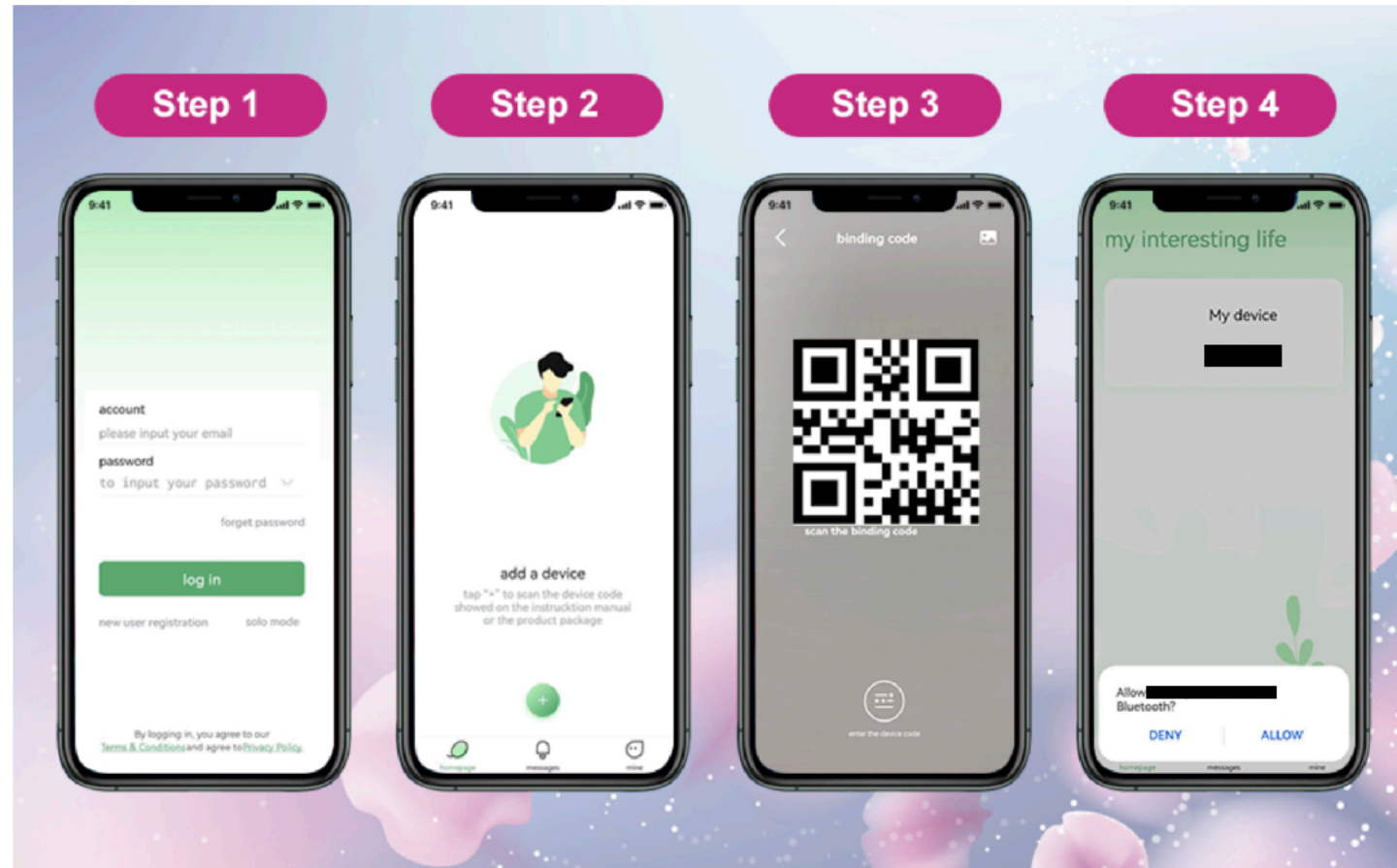


Bind device QR code
Number: "7555"



APP Download QR Code





Whether you are an user of Apple or Android, you can download the [REDACTED] in your mobile phone. You also can scan the **code from fourth picture** to download the APP.

1. You should create an account to log in.
2. Add a device to play, you should click the plus on the bottom of screen.
3. You can scan the **code from fifth picture** or input "5434" to add the device.

amazon.com/Female

3 sustainability features \$35 shipped by Amazon 3 sustainability features 3 sustainability features 1 sustainability feature

From the brand

Binding the phone to the device

1945

Cancel Yes



1 0 - > " < > done

3. Scan QR code to bind.

Binding Code:

1945

Home



My device



4. Control the vibrator.



Remote Vibrator

Fema

amazon.com/Vibrating

★

Incognito

AllMedical CareAmazon BasicsBest SellersBooksRegistryNew ReleasesToday's DealsGift CardsSmart HomeGroceriesPrimePharmacyCustomer ServiceMusic

Health & Personal CareHousehold SuppliesVitamins & Diet SupplementsBaby & Child CareHealth CareSports NutritionSexual WellnessHealth & WellnessMedical Supplies & EquipmentFSA Eligible Items

Health & Household > Sexual Wellness > Adult Toys & Games > Sex Toys > Anal Sex Toys > Beads

Long Distance Interaction

How to add a vibrator?

1. Scan the QR code on the left to download the app (or search for " " in APP Store or Google Play).

2. Hold the power button for about 2 secs to turn it on . And keep your phone 's Bluetooth on .

3. Tap "+" on the homepage to add a device , scan the QR code on the right or enter the product code "3183".

App

3183

Vibrating

Vibrating

Vibrating

Prostate

G

Sex

Pleasure

Brand:

4.6

(97)

50+ bought in past month

\$12⁵⁹

(\$12.59 / count)

Get Fast, Free Shipping with Amazon Prime

Save 5% at checkout

Terms

Get \$50 off instantly: Pay \$0.00 \$12.59 upon approval for Amazon Visa.

No annual fee.

Brand

Product Care

Instructions

Number of Batteries

Hand Wash

1 Lithium Ion batteries required. (included)

About this item

prime

Enjoy fast, free delivery, exclusive deals, and award-winning movies & TV shows.

Join Prime

\$12⁵⁹

(\$12.59 / count)

Get Fast, Free Shipping with Amazon Prime

FREE delivery Sunday, January 18 on orders shipped by Amazon over \$35

Or Prime members get FREE delivery Tomorrow, January 14.

Join Prime

Delivering to Chicago 60606 - Update location

In Stock

Quantity: 1

Add to cart

Buy Now

Click to see full view

22



Diddy



Great Vibration

App A: Hooking into Encrypted Traffic

- Hook OpenSSL where data has to be in plaintext:
 - `EVP_EncryptUpdate` → read plaintext going out
 - `EVP_DecryptUpdate` → read plaintext coming back
- We can inspect, but cannot talk back yet
- One more hook, at cipher initialization, to read key and IV from memory:
 - `EVP_EncryptInit_ex` → read key and IV from memory

Behold a bunch of shitty screenshots!

```
1  setTimeout(function() {
2      var evp_encrypt = Module.findExportByName("libcrypto.so", "EVP_EncryptUpdate");
3      if (evp_encrypt) {
4          Interceptor.attach(evp_encrypt, {
5              onEnter: function(args) {
6                  var inlen = args[4].toInt32();
7                  try {
8                      console.log("[EVP_Encrypt] " + Memory.readUtf8String(args[3], inlen));
9                  } catch(e) {
10                     console.log("[EVP_Encrypt] " + inlen + " bytes (binary)");
11                 }
12             }
13         });
14         console.log("[+] Hooked EVP_EncryptUpdate");
15     } else {
16         console.log("[-] EVP_EncryptUpdate not found");
17     }
18 }, 1000);
```

```
30  var evp_decrypt = mod.findExportByName("EVP_DecryptUpdate");
31  if (evp_decrypt) {
32      Interceptor.attach(evp_decrypt, {
33          onEnter: function(args) {
34              this.out = args[1];
35              this.outlen = args[2];
36          },
37          onLeave: function(ret) {
38              try {
39                  var len = Memory.readU32(this.outlen);
40                  var data = Memory.readUtf8String(this.out, len);
41                  console.log("[DECRYPT] " + data);
```

```
17  var evp_enc_init = mod.findExportByName("EVP_EncryptInit_ex");
18  Interceptor.attach(evp_enc_init, {
19      onEnter: function(args) {
20          var key = args[3];
21          var iv = args[4];
22          if (key && !key.isNull()) {
23              console.log("[ENC KEY] " + toHex(key.readByteArray(32), 32));
24          }
25          if (iv && !iv.isNull()) {
26              console.log("[ENC IV] " + toHex(iv.readByteArray(16), 16));
27          }
28      }
29  });
```

```

    / _ |   Frida 17.5.2 - A world-class dynamic instrumentation toolkit
  | (| |
    > _ |   Commands:
  /_/ |_ |     help      -> Displays the help system
        . . . . object?   -> Display information about 'object'
        . . . . exit/quit -> Exit
        . . . .
        . . . . More info at https://frida.re/docs/home/
        . . . .
        . . . . Connected to G011A (id=127.0.0.1:21503)
Spawning '[REDACTED]'...
[*] Setting up crypto hooks...
Spawned '[REDACTED]'. Resuming main thread!
[G011A:[REDACTED]]-> [+] Found libcrypto at 0x7f2393a53000
[+] Helper functions: getCipher=yes, getCipherName=no, getKeyLen=yes, getIvLen=yes
[+] Hooked EVP_EncryptUpdate
[+] Hooked EVP_DecryptUpdate
[+] Crypto hooks ready!

=====
[#] Android Bypass for various Certificate Pinning methods [#]
=====
[-] OkHTTPv3 {2} pinner not found
[-] Trustkit {1} pinner not found
[-] Trustkit {2} pinner not found
[-] Trustkit {3} pinner not found
[-] Appcelerator PinningTrustManager pinner not found

```

```
Administrator: Wind X Administrator: Wind X Administrator: Wind X /m/c/U/M/D/T/4/b/l X + v - □ X

[KEY LENGTH] 16 bytes (128 bits)
[IV LENGTH] 16 bytes
[CTX DUMP] First 128 bytes of EVP_CIPHER_CTX:
c0 46 ba 93 [REDACTED]
48 37 71 4d [REDACTED]
[REDACTED]

[ENCRYPT] {}
[+] Bypassing OkHTTPv3 {4}: api. [REDACTED]
[+] Bypassing OkHTTPv3 {4}: api. [REDACTED]
[+] Bypassing OkHTTPv3 {4}: api. [REDACTED]
[+] Bypassing OkHTTPv3 {4}: api. [REDACTED]
[+] Bypassing OkHTTPv3 {4}: api. [REDACTED]
[ENCRYPT hex] 1e ee 36 1c d1 d3 f5 60 a8 24 a6 e6 a3 2a fb a5 ca 7b 7e 17 42 b9 af d9 b5 a6 42 88 cb 5d 93 e1
27 dd 06 fc 39 6a bd 2d 9f 42 7a 24 7e 5c 39 ee fd 61 b6 3f c7 69 92 c0 ea 61 cd 90 84 a2 f9 bf db 62 0e 02 84
43 89 ea 09 d8 3f 24 ed fe 7c 00 0a 94 77 10 52 a3 96 ff 18 71 37 53 68 5d 0e 01 d7 ac fe 6c 4d 10 9e 25 85 b
a 13 c8 57 df e1 3a d9 db 15 47 99 1d 1d 7b 89 48 b9 7d 1d f7 01 95 01 cc d4 e0 d9 e0 b0 1d d0 a9 80 81 cb 09
fa b0 a3 2e a1 41 70 49 eb 3e 0b c5 34 c9 63 83 b3 c1 c9 c1 f6 2f f6 ce 9a 08 98 66 bf 02 66 ca a5 94 51 64 b9
77 35 e8 36 e0 85 58 8d c6 6f 72 b2 6b 44 f4 87 08 30 e9 db ac
[DECRYPT] {"data":{"name":"[REDACTED] Remote connection","app_version":"[REDACTED]","app_log":"1. Fix bugs\n2. Opt
imize the experience","app_path":"https://sextoy.[REDACTED]?g=Extend\u0026m=App\u0026a=getWchatQrco
de\u0026id=30","app_url":"https://image.[REDACTED].apk","is_forced":1},"response"
:{"result":true,"errorCode":10000,"msg":"成功"}
[+] Bypassing TrustManagerImpl (Android > 7) checkTrustedRecursive check for: api. [REDACTED]
[ENCRYPT hex] 9e 16 1d 10 b5 40 5a 8b 88 d0 54 bd cc b5 5c 9c fd 65 a9 3f fd 0a 61 c6 81 24 e4 c5 7b b1 69 f0
d6 92 e2 c3 ea 34 d1 6a f6 b2 b6 9d cc fe a1 e4 d6 47 6c 03 d2 94 e3 13 62 e7 c5 70 a4 42 61 d4 ad 4e 9b 86 0f
2d 64 b8 1e bf 49 86 1b 05 46 10 d8 ab d0 cc 2e 9b 89 cd 32 d6 8f b2 f9 20 77 a3 32 30 82 b8 e2 cc 30 33 65 3
4 02 dc 5c da 1c 4f ee cc ae ab ae cd e8 26 e8 46 83 74 d4 5b 98 d1 41 d1 69 c6 53 0e 8e 74 a0 24 a5 26 33 9b
b9 62 ca dd dd 40 ec d5 53 70 2b 87 d3 de 64 de b4 fa 78 5d 30 18 75 c6 42 9a 02 df 51 49 14 ed 53 3e aa 7d a7
18 b9 4b 3f 1e 37 68 0a 06 b0 27 20 44 02 1e a6 46 c8 eb a8 63
```

IV



VeryNiceLongUniqueString2026:VeryNiceLongUniqueString2026



KEY

App A: Vulnerabilities

- CWE-321: Use of Hard-coded Cryptographic Key
- CWE-329: Generation of Predictable IV with CBC Mode
- Since same key in all binaries, one extraction potentially compromises every user

App B: Static Analysis of Codebase

- No SSL pinning, so proxy setup is trivial
- Decompile the APK with JADX
- Two critical secrets in plaintext:
 - AES-128 key: hardcoded string constant in a utility class
 - HMAC-SHA256 secret: hardcoded, used for Tencent-style TLS UserSig auth tokens
- Dynamic instrumentation not required to build crypto profile

Text search: SECRET_KEY

Search for text: SECRET_KEY

Search definitions of:

☐ Class ☐ Method ☐ Field ☒ Code ☐ Resource ☐ Comments

Limit to package:

Node	Code
com.	public static final String PARAM_APP_SECRET_KEY = "paramAppSecret";
com.	private static final String SECRET_KEY = "██████████";
com.	cipher.init(2, new SecretKeySpec(SECRET_KEY.getBytes("UTF-8"), AES_ALGORITHM));
com.	cipher.init(1, new SecretKeySpec(SECRET_KEY.getBytes("UTF-8"), AES_ALGORITHM));
com.	private static final String SECRET_KEY = "██████████";
com.	SecretKeySpec secretKeySpec = new SecretKeySpec(SECRET_KEY.getBytes(charset), AL
com.	cipher.init(1, new SecretKeySpec(SECRET_KEY.getBytes(charset), ALGORITHM));

Load all Load more Stop Found 7 (complete) Sort results

☐ Keep open Copy All Open Cancel

```
10 public class AesUtils {
11     private static final String ALGORITHM = "AES";
12     private static final int KEY_SIZE = 128;
13     private static final String SECRET_KEY = "████████████████████";
14
15     public static String decrypt(String str) throws Exception {
16         Charset charset = StandardCharsets.UTF_8;
17         SecretKeySpec secretKeySpec = new SecretKeySpec(SECRET_KEY.getBytes(charset), ALGORITHM);
18         Cipher cipher = Cipher.getInstance(ALGORITHM);
19         cipher.init(2, secretKeySpec);
20         return new String(cipher.doFinal(Base64.getDecoder().decode(str)), charset);
21     }
```

```
13 public class GenerateTestUserSig {  
14     private static final int EXPIRETIME = ██████████;  
15     public static final int SDKAPPID = ██████████;  
16     public static final int SDKAPPID_TEST = ██████████;  
17     private static final String SECRETKEY = "████████████████████████████████████████";
```

CrypticBurp: Making Fuzzing Easier

- Burp Suite extension that adds a "Decrypted" editor tab
- Workflow:
 1. Observe encrypted request or response
 2. CrypticBurp auto-decrypts incoming traffic
 3. Edit requests in plaintext
 4. Forward request, that re-encrypts on the way out
 5. Server accepts modified ciphertext
- JSON profiles per target: swap apps with one click
- Supports AES-CBC, AES-ECB, AES-GCM, DES, 3DES

```
1  {
2    "name": [REDACTED]
3    "description": "[REDACTED]",
4    "target_host": "[REDACTED]",
5    "target_path": "[REDACTED]",
6    "decrypt_query": true,
7    "decrypt_request_body": false,
8    "decrypt_response_body": true,
9    "request_body_type": "Raw",
10   "request_body_field": "",
11   "response_body_type": "Raw",
12   "response_body_field": "",
13   "algorithm": "AES/CBC/NoPadding",
14   "key": "[REDACTED]",
15   "iv": "[REDACTED]",
16   "key_format": "ASCII",
17   "iv_same_as_key": true,
18   "encoding": "Base64",
19   "padding": "Tab (0x09)"
20 }
```

CrypticBurp

CrypticBurp

Target

Host:

Path (optional):

Decrypt/Encrypt Locations

☒ Query String (GET params)

☐ Request Body

☒ Response Body

Type:

Raw

Field:

Type:

Raw

Field:

Crypto Settings

Algorithm:

AES/CBC/NoPadding

Key:

IV:

Encoding:

Base64

Custom Padding:

Tab (0x09)

ASCII

☒ Same as Key

Apply Config

Test Decrypt

Save Profile

Load Profile

Test Area

Request

Pretty

Raw

Hex

Decrypted



```
1 GET /[REDACTED]/user/getUserInfo?
  [REDACTED]
2 Host: [REDACTED]
3 Phonesystem: android
4 Appname: ls ri
5 Deviceid: [REDACTED]
6 Lang: en
7 User-Agent: Dalvik/2.1.0 (Linux; U; Android 9; GO11A Build/PI)
8 Theme: light
9 Phonemodel: google_GO11A
10 Systemcode: jv0
11 Barcode:
12 Versioncode: [REDACTED]
13 Accept-Encoding: gzip, deflate, br
14 Connection: keep-alive
15
16
```

Response

Pretty

Raw

Hex

Render

Decrypted

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.22.1
3 Date: Tue, 03 Feb 2026 04:46:55 GMT
4 Content-Type: text/plain; charset=utf-8
5 Connection: keep-alive
6 Access-Control-Allow-Credentials: true
7 Access-Control-Allow-Headers: *
8 Access-Control-Allow-Methods: POST, GET, OPTIONS, PUT, DELETE, UPDATE
9 Access-Control-Allow-Origin: *
10 Access-Control-Expose-Headers: Content-Length
11 Access-Control-Max-Age: 86400
12 Content-Length: 2712
13
14 aEfMBiquEYyHiEVuPy8792u5UhAJ52OLR1yJK9ocZAhgBwANHHzRNv/0Om28EhFd+GZIQZHn+OnpDPwe97nqogTap+s
  FPiaCah4iZ++ZSu9uYr9Pt10is0dql4sVj1lscqhcRHgaTaROAaoWO7/ccssqNeJyEt97eqkYca+PbnrOHNK3HMR8hu
  ++HF1ktpiCO0BjcH0We3VeQOVXA6NXpYmuUf8XvFCVW6Vfb9hY15nQtQ5wqvxx0ak0oGtsr+D06+zyieYNF0Y7wQnag
```

3i3JsJ5Xc1AAvIdeSzogizhA9ieJiTUP5iNTYs748SbFebI.Bx6Osmvii4HkQ13i/BezQzO==

Response

Pretty Raw Hex Render Decrypted

```
{
  "img": "",
  "name": "",
  "id": 0,
  "desc": "",
  "status": 0
},
"nickname": " ",
"deepinAnchorFilterCard": 0,
"langs": [],
"isRecharge": false,
"advertSetBanner": 0,
"email": " ",
"amount": 0,
"lastSignTime": ,
"isThirdLogin": false,
"msgPrice": 1,
"star": "@@@",
"enableAd": 0,
"sex": "1",
"remainTime": 86400,
"avatar": "https:// .png",
"message": "",
"followMeCount": 0,
"interactivePrice": 10,
"isVip": 0,
"zhCountry": "@@",
"enableTask": 0,
"isHdActPop": 0,
"vipLeftTime": -1770014273,
"img_frame": 0,
"deepinUnlockCard": 0,
"IsSearchByEmail": "1",
"response": {
  "msg": "Success",
  "errorCode": 10000,
  "result": true
},
"canVideo": false,
"giftCoin": 0,
"fishingBottle": 0,
"idnum": " ",
"age": 18,
"isComplete": 1,
"username": " "
}
```

Request

Pretty

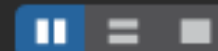
Raw

Hex



```
1 POST /auth/login HTTP/1.1
2 token:
3 language: en
4 device: android
5 Content-Type: application/x-www-form-urlencoded
6 Content-Length: 46
7 Host: [REDACTED]
8 Connection: keep-alive
9 Accept-Encoding: gzip, deflate, br
10 User-Agent: okhttp/4.12.0
11
12 password=22222&email=bottles[REDACTED]
```

Response



Pretty

Raw

Hex

Render

Decrypted



```
1 HTTP/1.1 200
2 Server: nginx
3 Date: Tue, 17 Feb 2026 11:47:56 GMT
4 Content-Type: application/json
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Vary: Origin
8 Vary: Access-Control-Request-Method
9 Vary: Access-Control-Request-Headers
10 Set-Cookie: server_name_session=[REDACTED] Max-Age=86400; httponly;
    path=/
11 Content-Length: 318
12
13 {
  "code":1000,
  "msg":"",
  "data":
  "[REDACTED]OUMd5
  iYpEay
  vBg=="
}
```

Request

Pretty

Raw

Hex



```
1 GET /app/personal/info HTTP/1.1
2 token:
3 language: en
4 device: android
5 Host: 
6 Connection: keep-alive
7 Accept-Encoding: gzip, deflate, br
8 User-Agent: okhttp/4.12.0
9
10
```

Response

Pretty

Raw

Hex

Render

Decrypted

```
{
  "msg": "æ00å00",
  "code": 1000,
  "data":
    "{\\"addFriendStatus\\":0,\\"appSys\\":1,\\"appVersion\\":\\"\\",\\"banEndTime\\":null,\\"chatServe\\":\\"http://[REDACTED]\\.com\\",\\"code\\":\\"[REDACTED]\\",\\"codeFindMe\\":1,\\"country\\":\\"us\\",\\"createTime\\":1771315714000,\\"email\\":\\"bottles[REDACTED]\\",\\"emailFindMe\\":1,\\"growthValue\\":0,\\"id\\":[REDACTED],\\"image\\":\\"\\",\\"isAuthor\\":0,\\"isOfficial\\":0,\\"lastViolationTime\\":null,\\"loginIp\\":\\"[REDACTED]\\",\\"nickname\\":\\"[REDACTED]\\",\\"numberReports\\":0,\\"password\\":\\"e3ceb5881a0a1fdaad01296d7554868d\\",\\"periodCycLen\\":28,\\"periodLen\\":5,\\"phone\\":\\"\\",\\"phoneFindMe\\":null,\\"pointsBalance\\":0,\\"remark\\":null,\\"sex\\":1,\\"shieldMoments\\":0,\\"speakStatus\\":1,\\"status\\":1,\\"unreadMsg\\":0,\\"updateTime\\":1771328876550,\\"usign\\":null}"
}
```

Hash	Type	Result
e3ceb5881a0a1fdaad01296d7554868d	md5	222222

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

Send

Cancel

<

>

Burp AI

Request

PrettyRawHexDecrypted

=== QUERY PARAMS ===
&userid= &sessionid= &version=ls_ri_3.1.8&lang=en

Response

PrettyRawHexRenderDecrypted

```
{
  "id": 0,
  "desc": "",
  "status": 0
},
"nickname": "",
"deepinAnchorFilterCard": 0,
"langs": [],
"isRecharge": false,
"advertSetBanner": 0,
"email": "",
"amount": 0,
"lastSignTime": 1770012357,
"isThirdLogin": false,
"msgPrice": 1,
"star": "000",
"enableAd": 0,
"sex": "1",
"remainTime": 86400,
"avatar": "",
"message": "",
"followMeCount": 0,
"interactivePrice": 10,
"isVip": 0,
"zhCountry": "00",
"enableTask": 0,
"isHdActPop": 0,
"vipLeftTime": -1770094015,
"img_frame": 0,
"deepinUnlockCard": 0,
"IsSearchByEmail": "1",
"response": {
  "msg": "Success",
  "errorCode": 10000,
  "result": true
},
"canVideo": false,
"giftCoin": 0,
"fishingBottle": 0,
"idnum": "",
"age": 18,
"isComplete": 1,
"username": ""
}
```

The Decrypted Data

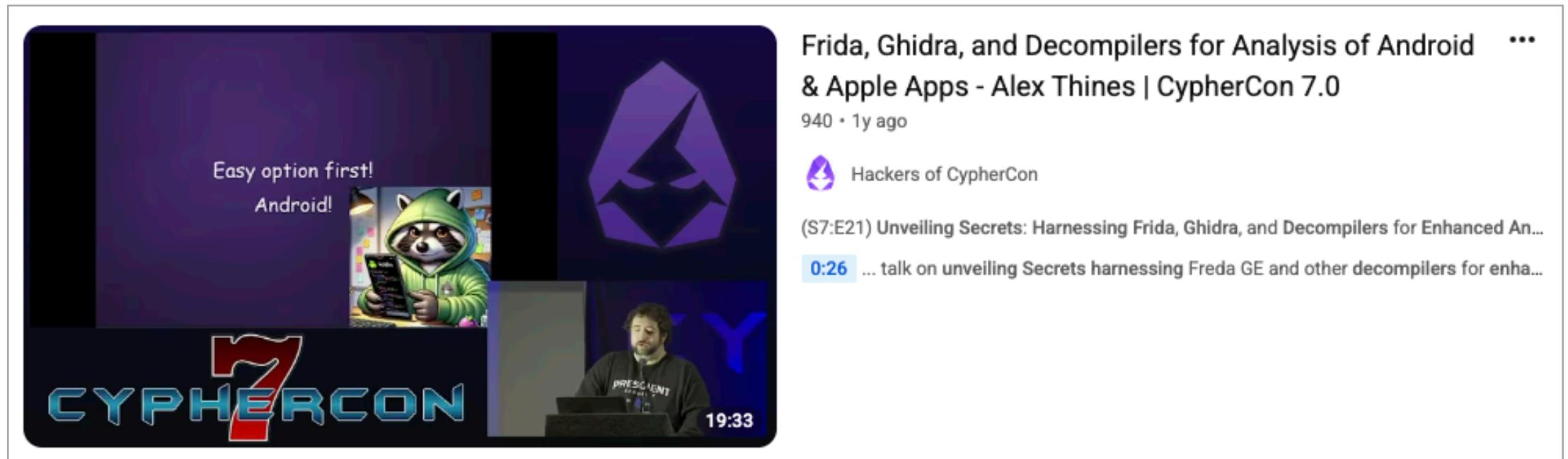
- Decrypted traffic revealed:
 - Email addresses, nicknames, birthdates
 - Country of residence, user IDs
 - Session tokens (account takeover risk)
 - VIP and subscription status
 - Device control commands and heartbeats
 - Password hashes (MD5)
- One hardcoded key shared across every installation
- All traffic routed to one jurisdiction's infrastructure

Some Recommendations

- What better looks like:
 - Per-session key derivation (e.g., ECDHE at login)
 - Secure key storage (Android Keystore, not the binary)
 - Random, unique IVs per operation
 - Authenticated encryption (AES-GCM)
- Application-layer encryption is a valid defense-in-depth measure
 - Needs to be built on proper key management, not hardcoded secrets shipped with binary

A Much Nicer Talk to Watch!

Alex Thines (sparky23172): "Harnessing Frida, Ghidra, and Decompilers for Enhanced Analysis of Android and Apple Applications" presented at CypherCon 7. (<https://www.youtube.com/watch?v=RoNppaG1re4>)



wict0rious/ CrypticBurp



A really simple encryption/decryption Burp extension



1

Contributor



0

Issues



1

Star



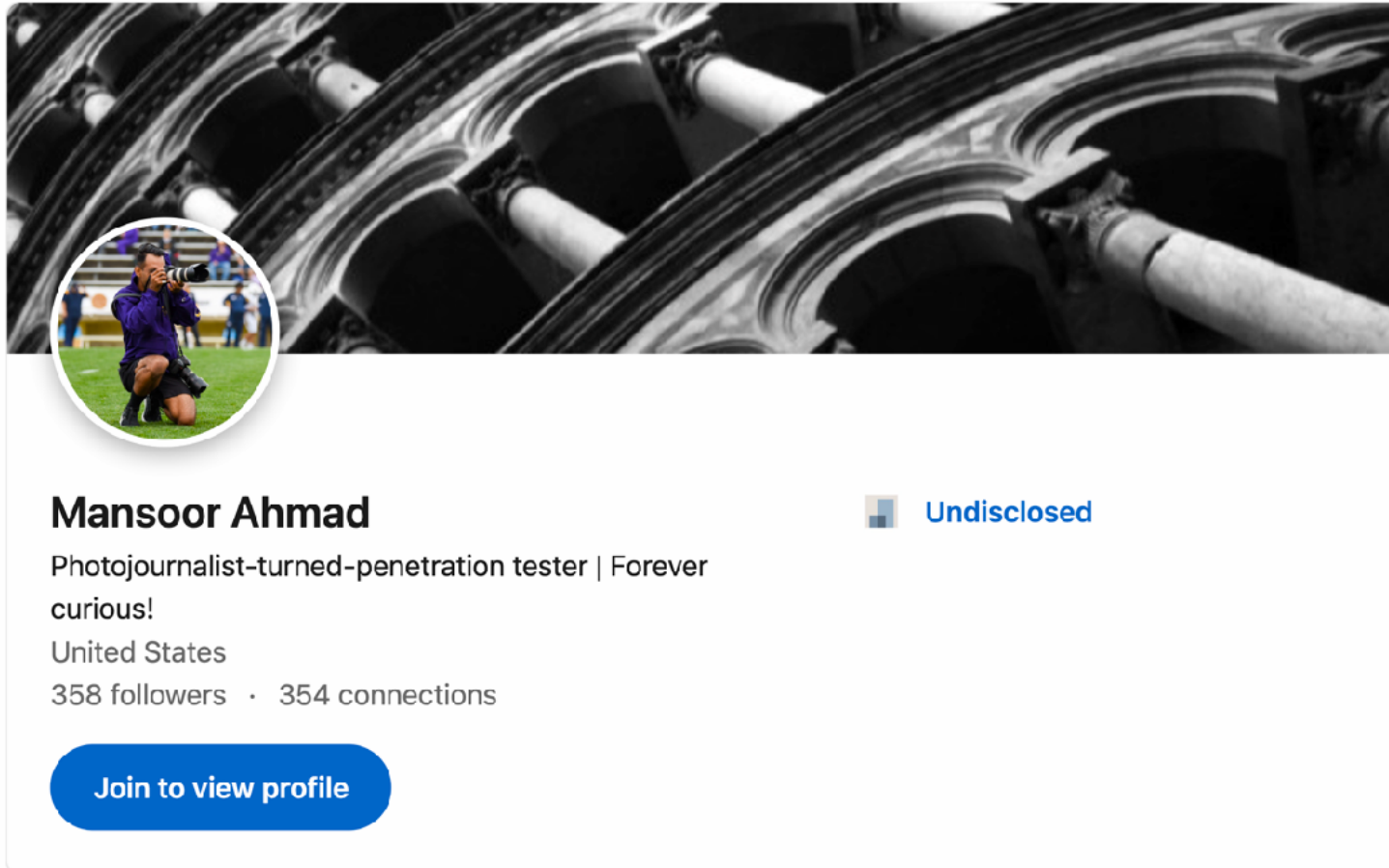
0

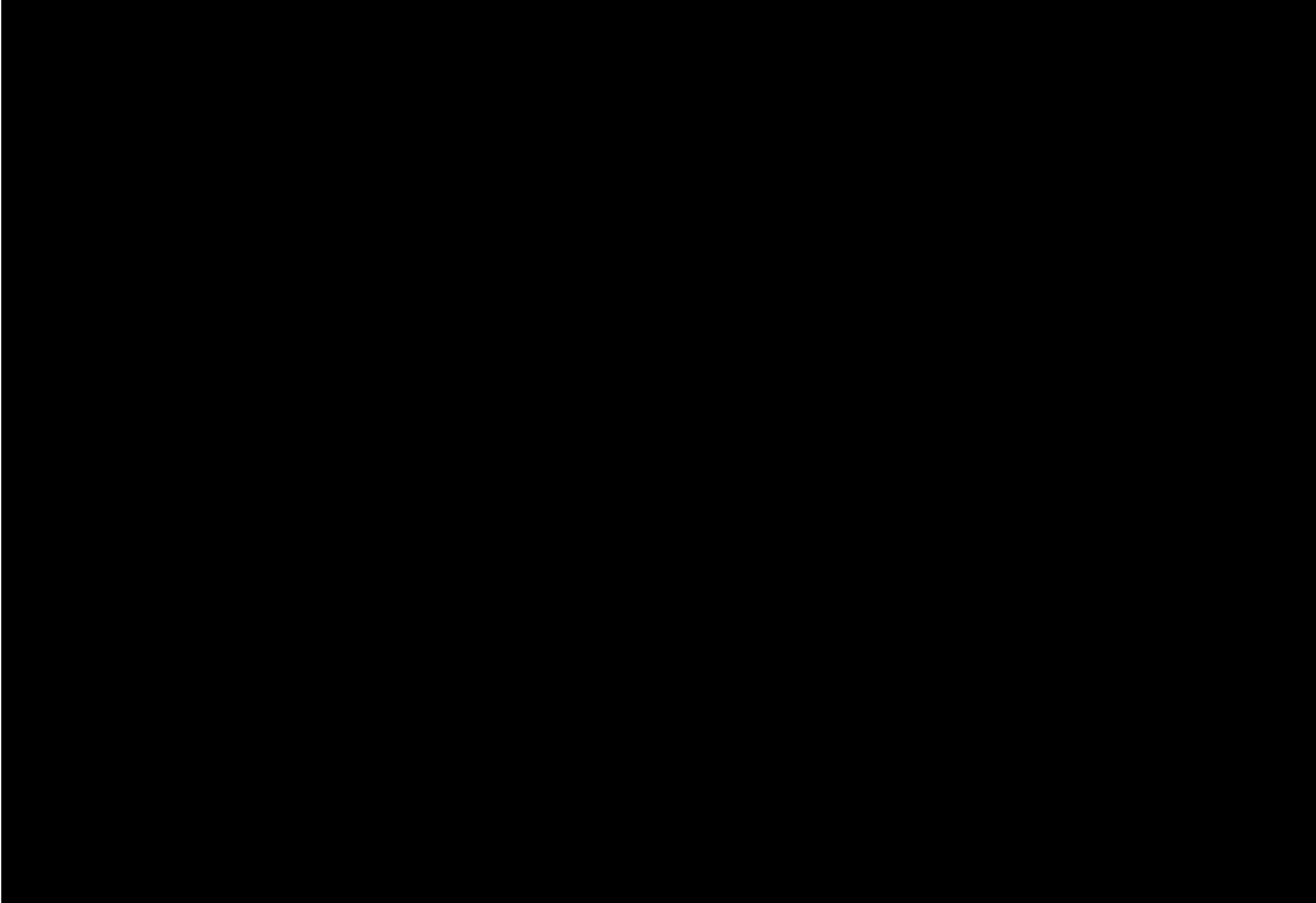
Forks



Increase Shareholder Value With Me Here

www.linkedin.com/in/mansoor-ahmad-khan/





Thank You!